

## Day 5 JWT Authentication

### Date

August 25, 2026

### Overview

Implemented JWT (JSON Web Token) authentication for REST API security. Added token generation on login, JWT validation filter for protected endpoints, and stateless session management.

### Tech Stack

- Java 26
- Spring Boot 4.1.0
- Lombok 1.18.46
- MongoDB (clinic\_db)
- Thymeleaf + Bootstrap 5
- Spring Security
- JJWT 0.12.6

### Files Created

#### New Java Files

1. `com.clinic.dto.AuthResponseDto` - Token response with token, tokenType, username, role
2. `com.clinic.security.JwtUtil` - Token generation, validation, extraction
3. `com.clinic.security.JwtAuthenticationFilter` - Request interceptor for Bearer token validation

#### Updated Java Files

1. `com.clinic.controller.AuthRestController` - Login returns JWT token via `AuthResponseDto`
2. `com.clinic.config.SecurityConfig` - Stateless sessions, JWT filter chain, `AuthenticationManager` bean

### REST API Endpoints

| Method | Endpoint                        | Description                           |
|--------|---------------------------------|---------------------------------------|
| POST   | <code>/api/auth/register</code> | Register new user                     |
| POST   | <code>/api/auth/login</code>    | Login and receive JWT token           |
| GET    | <code>/api/auth/me</code>       | Get user by username (requires token) |

### JWT Token Flow

1. Client sends POST `/api/auth/login` with credentials
2. Server validates credentials and generates JWT token
3. Token contains: username, role, issuedAt, expiration (24 hours)
4. Client includes token in Authorization header: Bearer
5. `JwtAuthenticationFilter` validates token on every request

6. `SecurityContext` is set with user authorities from token

## Key Features Implemented

1. JWT token generation with secret key and 24-hour expiry
2. Token validation and extraction (username, role)
3. JwtAuthenticationFilter intercepts all requests
4. Stateless session management for REST API
5. Bearer token authentication for API endpoints
6. Form login still works for Thymeleaf web pages

## Testing

### REST API Login (Postman)

POST /api/auth/login { "username": "admin", "password": "admin123" } Response: 200 OK with { token, tokenType, username, role }

### Protected Endpoint with Token

GET /api/auth/me?username=admin Header: Authorization: Bearer Response: 200 OK with user data

### Protected Endpoint without Token

GET /api/auth/me?username=admin (No Authorization header) Response: 403 Forbidden

## Git Commit

feat: add JWT authentication with token generation and validation filter